Vendor Risk Management Policy

Policy: PTP-SOP-04-004 | Owner: **Vendor Risk Management Office** (VRMO) | Adobe Confidential

1. Overview

1.1. Third Party Risk Management

Adobe's global vendor base comprises thousands of active vendors. Each of these vendors presents a range of risks that, if not adequately managed, will cause a disruption to the Company's operations while also potentially impacting the quality of Adobe's services or products. Continued exposure to these risks without proper control will lead to long term effects such as increased cost, loss of revenue, regulatory non-compliance, and reputational damage.

1.2. Vendor Risk Management Office

To help protect Adobe from vendor risk exposures, the Vendor Risk Management Office (VRMO) has been delegated the authority to implement consistent risk management practices working under the VRMO Charter and framework and through the establishment and enforcement of this policy. The VRMO partners with various groups within Adobe, including but not limited to procurement, legal, business resilience, Information security, privacy, and ethics & compliance to implement a global and effective enterprise-wide vendor risk management ecosystem.

The VRMO will provide training periodically throughout the year for Adobe employees to train employees on the importance of vendor risk management to the company and how best to manage the vendor risk management ecosystem to protect Adobe effectively.

Obligations of Adobe's third-party vendors with regard to risk mitigation activities and those of their subcontractors (Adobe's 4th party vendors) are typically managed through contractual terms and conditions and relevant external facing policies.

Contingent workers are managed via the contingent worker program, details here.

Strategy. VRMO's strategy consists of a three-step approach:

i. **Identify:** VRMO partners with various risk domains as mentioned in 1.2 above to identify vendor risk through onboarding, due diligence reviews and continuous monitoring of the service or products supplied to Adobe.
ii. **Mitigate:** If risks are identified, the VRMO in collaboration with risk assessors and other stakeholders will assess the potential impact to Adobe and determine if the risk is acceptable, can be eliminated or can be mitigated through mitigation procedures.
iii. **Manage:** Once the risk has been evaluated, the risk will be managed through the full lifecycle of the service or product supplied to Adobe until the vendor, service or product is off boarded..

Table of Contents

1. Overview
2. Scope
3. Vendor Onboarding
4. Risk Reviews
5. Engagement Decision
6. Transacting
7. Reassessment
8. Off-boarding
9. Reporting & Training
10. Responsibility by Roles
11. Exceptions
12. Violations
13. Definitions
14. Related Documents
15. Document History

The VRMO uses various 3rd party solutions and platforms to execute its strategy.

The Risk Advisory & Assurance Services (RAAS) organization will periodically provide independent and objective assurance over the VRMO's governance, risk management and internal control (GRC) processes.

1.2.1 **Policy.** This policy is a critical document related to third party risk management It and other polices referred to in Section 14; "Related Documents" govern the third-party ecosystem within Adobe.

1.2.2 **Expectation.** It is critical that Adobe Personnel partner with the VRMO and follow approved vendor onboarding and risk management processes to increase business value, and appropriately limit possible individual and organizational liability.

1.2.3 **Questions.** For any questions regarding this policy, consult the VRMO at vrmo@adobe.com.

2. Scope

2.1. Policy Scope

This policy applies to all Adobe companies and locations world-wide.

This policy applies to all Adobe Personnel, which includes any regular employees, Adobe-paid temporary employees, interns, and contingent workers (including agency temporary employees, independent contractors, and vendor employees). Violations of this policy may be reported to business unit leadership and Corporate Compliance as appropriate.

3. Vendor Onboarding

3.1. Choice of Vendor

Adobe Personnel should make reasonable efforts to buy from preferred or approved vendors rather than engage new vendors. A largely fragmented vendor base increases risk for Adobe and dilutes Adobe spend.

3.2. Business Owner's Responsibilities

3.2.1 The Business Owner must submit a New Supplier Justification (NSJ) to onboard a new vendor. Only people that fully understand what is being procured should complete an NSJ or a data classification. If the individual submitting an NSJ is not sure about how to answer questions within an NSJ or any part within the graphiteConnect process, they must make every reasonable effort to investigate within their organization or contact vrmo@adobe.com to seek clarification before submitting the NSJ.

3.2.2 If a vendor will process, create, access, transmit, transfer, or store Adobe Confidential Information or Adobe Information, including Personal Information, in any manner, based on the vendor risk profile, the Business Owner must oversee the vendor's requirement to comply with the Information Security and Privacy Requirements available at https://www.adobe.com/content/dam/cc/en/legal/terms/enterprise/pdfs/Information_Security_and_Privacy_Requirements.pdf

3.2.3 The information and privacy requirements will be part of Adobe's contractual general T & C's. Vendor personnel accessing such data must have appropriate background checks as per local standards. Where a contract is not applicable a Non-Disclosure Agreement (NDA) must be in place before sharing sensitive or confidential information with a vendor. The Business Owner is responsible for identifying that restricted or confidential data is being shared with the vendor and work with the VRMO, information security team, privacy, procurement or / and procurement legal to ensure the appropriate contract and controls are in place.

3.2.4 When onboarding vendors, the Business Owner must review the Global Procurement Policy and follow the requirements within that policy.

3.2.5 All subcontracting engagements must have an *'Adobe Global Services Subcontracting Agreement'* in place or equivalent legal approved vendor agreement before activities can commence. Within the Adobe Global Services Subcontracting Agreement, the "Adobe Provider Data Processing Agreement: Information Security and Privacy Terms" are referenced. This contractually obligates the subcontracting vendor to hold their vendors (Adobe's 4th party vendor) to the same standards as Adobe hold the subcontractor.

3.2.6 When onboarding contingent workers (an Agency-paid Temporary Employee, Independent Contractor, Vendor Worker), managers must review the Global Contingent Worker Policy and follow the country-specific onboarding requirements.

3.3. Onboarding Procedures Overview

The vendor onboarding and risk assessment process is documented within a lucid flow chart here for reference.

3.4. GraphiteConnect

Vendors must be fully on-boarded via Adobe's vendor onboarding partner, "graphiteConnect" and must be in a 'Ready to Transact' status before completing a Purchase Order, contract, or contract renewal.

3.4.1 **Source of Truth.** All data related to vendor risk (with the exception of contractual risk) must utilize graphiteConnect as the source of truth for all vendor related risk assessment activities (including data classification). Additionally, any risk assessment activity performed offline

must be uploaded or documented in graphiteConnect where possible or uploaded to a designated SharePoint location defined by the VRMO to ensure proper record keeping and accurate risk scoring.

3.4.2 **Access Management.** VRMO will maintain provisioning and access control to ensure effective access management of graphiteConnect.

3.5. Vendor Information

3.5.1 **New Supplier Justification (NSJ).** As part of a new vendor onboarding (including any subsequent data classifications*) Business Owners are required to provide accurate information about the vendor and the nature of the engagement. This data is critical for correct risk assessments. The NSJ and data classification must be documented by an employee who is knowledgeable about the service or products being acquired, this action cannot be delegated to an employee that has no or limited knowledge of the product or service being. If the person submitting an NSJ is not sure about how to answer questions within an NSJ or any part within the graphiteConnect process, the person must make every reasonable effort to investigate within their organization or contact vrmo@adobe.com to seek clarification before submitting the NSJ.

3.5.2 Vendors are required to retain all records associated with the delivery of the service to Adobe for at least a period of one year after the date of termination of the contract or after the delivery of the services to Adobe (which ever comes later) unless a data destruction request by Adobe is specifically made. However, vendor must comply with all local legal obligations around data retention such as, and without limitation, the GDPR and the Virginia Consumer Data Protection Act (2021).

4. Risk Reviews

The onboarding process provides the required due diligence and risk reviews. Each Vendor will be categorized with either a low, medium, or high-risk level and will be managed at a level appropriate to that risk. A vendor will not be onboarded until a full risk assessment is completed whereby all risk factors related to that engagement are evaluated and approved.

The following documents detail the areas that Adobe and graphiteConnect assess as part of an onboarding and risk assessment process to ensure vendors are appropriate entities to do business with.

- VRMO-DOC-001 Graphite Auto Validations
- VRMO-DOC-002 VRMO Process Standard
- VRMO-DOC-003 Financial Review Process

4.1. Risk Review Approach

Adobe contracts with vendors based on the services provided. Adobe procurement and procurement legal teams are responsible to ensure the correct contract is utilized for the services or products sourced from vendors. Insurance provisions, licensing requirements, experience and qualifications of vendors are managed within Adobe's contracting process. The Consulting and Services General Terms and Conditions (GTC's) is an example of the various contracting types that Adobe uses when engaging with Vendors. At times Adobe will use vendor paper based on the unique contracting situation. When vendor paper is used Adobe will consider the clauses within the Adobe standard contract to ensure the fundamental terms and conditions are represented within the final contract.

5. Engagement Decision

5.1. Uncooperative Vendors

If a vendor is uncooperative throughout the onboarding and risk review process, VRMO and risk reviewers will require the Business Owner to consider other alternatives where possible and appropriate. The VRMO has an offline assessment process to make exceptions to the process based on pre-defined use cases which have been assessed by the corresponding risk reviewers. The VRMO will review and approve such exceptions.

5.1.1 **Request for Proposal.** Certain services/products may need to undergo a Request for Proposal (RFP) depending on the spend involved. The RFx process is led by Strategic Sourcing. The finalist(s) in an RFx process must be onboarded via graphiteConnect and have a risk assessment performed before a contract is signed or business awarded. This is to ensure that a vendor is properly risk assessed and that the risk profile of the vendor is a critical part of the decision process of awarding Adobe business. Any Vendor that is not cooperative with

the vendor onboarding or risk assessment process or has not been approved by a risk assessor will not be selected for engagement. Any exceptions to this must be signed off by the VRMO director.

5.2. Risk Mitigation and Remediation

5.2.1 **Escalation Process.** If a vendor does not meet the minimum risk threshold where such a risk threshold has been defined or on an ad-hoc basis the risk reviewer escalates the risk to the VRMO, the VRMO and/or the risk reviewer will work with the business owner to develop a specified timeline for completion when no alternative vendor can be identified. The escalation process is defined here.

5.2.1.1 **VP Commitment.** Business owners and the VP of their department must sign-off on the risk via a risk acceptance form and agree to support any risk mitigation plans. The Business owner and the VP will acknowledge via the risk acceptance form the consequence of failing to comply with the risk mitigation plan which may result in termination of the service or product being sourced from the vendor.

5.2.1.2 **Risk Mitigation Tracking.** The VRMO is responsible and will oversee the risk mitigation process, working with the business owners and risk assessors on tasks that are due or overdue to confirm that the risk has been properly mitigated.

6. Reassessment

6.1. Periodic Reassessment

6.1.1 **Reassessment Schedule.** Existing Vendors will be asked to re-certify their answers and respond to any new open questions in the vendor form based on the below cadence. Once the vendor completes the outstanding tasks the risk assessors will perform a risk assessment. The risk assessment cadence is based on logic built within graphiteConnect based on the risk teams requirements. That logic is documented on graphiteConnect **here**.

6.1.2 **Risk Profile Change.** Vendor may need to undergo more frequent risk assessments than the schedule above when the Business Owner is aware that the vendor risk profile has changed, or a new use case or product/service is sourced since the last round of review.

7. Off-boarding

7.1. Vendor Off-boarding

7.1.1 If a business relationship with a vendor ends for whatever reason, the vendor must be off boarded by the Business Unit by requesting the vendor be 'disconnected' from Adobe via graphiteConnect. P2P-DTP-Vendors offboarding process documents that process.

7.1.2 **Inactive Vendor.** The VRMO will identify inactive vendors and work with Business Owners to carry out proper off-boarding procedures.

8. Reporting & Training

8.1.1 The VRMO will provide reports and dashboards that will facilitate holistic and enterprise-wide visibility into Adobe's third-party vendor risk profile.

8.1.2 On an annual basis VRMO leadership will provide a report to the CFO, Chief Accounting Officer, Corporate Controller, Chief Security Officer and Chief Compliance Officer on **vendor risk management** health metrics and key performance indicators as well as areas of concern and attention and focus for the following year(s)

8.1.3 All employees who are engaged in any aspect of the **vendor risk management** process are required to enroll within the Procurement 101 Training. Targeted employees will be required to complete the training every 2 years.

8.1.4 All employees are required to complete Side Arrangements Training and Trade compliance Training every 2 years and Security Awareness Training once a year.

9. Responsibilities by Roles

All Employees	• Read, understand, and comply with the terms of this policy and follow the related procedures.
All Managers	• Ensure that employees have the training and resources necessary to understand and comply with the terms of this policy.
Risk Assessors	• Comply with all provisions of this policy. • Perform Risk assessments to industry standards. • Meet any SLA's that are in place as part of the Third-Party Risk Management strategy.
Business Owner (Relationship Manager)	• Comply with all provisions of this policy. • Use current and preferred vendors where possible. • Promptly initiate a New Supplier Justification to onboard new Vendor.

	• Must not delegate NSJ or Data Classification completion to an employee that has no, or limited knowledge of the product or service being procured. • Update the VRMO and / or risk assessor teams if the nature or scope of the engagement changes • Complete risk mitigation activities. • Follow up with vendors to complete risk forms. • Gather data and material for any risk reviews that must be done offline. • Work with the VRMO and vendors to ensure data is returned / destroyed as part of vendor off boarding. • Ensure that vendors providing products or services to Adobe comply with this and other Adobe policies and that the vendor complies to all and any contractual commitments.
Vendor Risk Management Office (VRMO)	• Update this policy as necessary. • Assist and guide Adobe personnel in complying with this policy. • Provide training to Adobe employees, as instructed by the policy • Determine control measures and provide written guidance documenting such measures. • Monitor compliance with this policy. • Comply with all provisions of this policy.
Procurement Operations	• Monitor Contracts and PRs for new use cases for existing services or products. Notify the Business Owner to initiate a data classification in such cases. • Ensure vendors are fully risk assessed with no tasks pending within the third-party ecosystem before a contract is signed or renewed. • Comply with all provisions of this policy.
Strategic Sourcing	• Ensure final participants of an RFx process are onboarded and risk assessed within the third-party ecosystem before awarding business. • Manage contractual risk in accordance with the procurement process and policy. • Ensure vendors are fully risk assessed with no tasks pending within the third-party ecosystem before a contract is signed or renewed. • Monitor Contracts and PRs for new use cases for existing services or products. Notify the Business Owner to initiate a data classification in such cases. • Comply with all provisions of this policy.
Procurement Legal	• Action and complete contractual tasks within the third-party risk review. • Ensure vendors are fully risk assessed with no tasks pending within the third-party ecosystem before a contract is signed or renewed. • Manage contractual risk in accordance with the procurement process and policy. • Comply with all provisions of this policy.
Risk Advisory & Assurance Services (RAAS)	• The Internal Audit function at Adobe (RAAS) evaluates the vendor risk management program periodically assess whether the risks posed by third party relationships are being managed effectively.

10. Exceptions

10.1. Non-network Vendors Type 1

Certain vendors such as government entities (e.g., IRS) may bypass the normal vendor onboarding and risk review process described in this policy. Selected Business Owners are granted access to the "Non-network Supplier Request" group based on the qualifying use cases to assist with the onboarding of these vendors.

10.2. Vendors related to Mergers or Acquisitions (M&A)

When Adobe acquires a company, the vendors are also acquired. The M&A process for integrating acquired vendors is located here. The primary goal of the initial integration process is to ensure the acquired business model is not interrupted due to integration activities. Therefore, a full risk assessment is not performed as part of the initial vendor onboarding. Where Adobe standards and minimal risk thresholds are not met or cannot be evaluated, Adobe will move those services to other established vendors already in Adobe's approved vendor base.

10.3. Risk Screening Verification

Bi-annually, the VRMO will conduct an audit of vendors that have been systematically reviewed to ensure that system logic and risk screening verification is designed and functioning as expected. A root cause analysis of any issues identified will be completed. Results and remediation actions will be communicated to the applicable risk teams.

10.4. Work product Storage

Work product storage related to vendor risk management governed by the VRMO charter that cannot be held within the graphiteConnect solution and will be stored in secure SharePoint locations and similar data storage locations within Adobe's firewall. Contracts are stored in Adobe's contract life management system (Ariba)

10.5. Other exceptions

Any other exceptions to this policy must be approved in writing by VRMO leadership or VP of Accounting or above in the Accounting Controller organization in Adobe.

11. Violations

Anyone who violates this policy may be subject to disciplinary action up to and including termination of employment or contract.

12. Definitions

For purposes of this policy, the following terms have the meanings indicated below:

- **"Adobe Personnel"** means any regular employees, Adobe-paid temporary employees, interns, and contingent workers (including agency temporary employees, independent contractors, and vendor employees.)
- **"Business Owner"** or **"Relationship Manager**" means the person responsible for the relationship with the Vendor and the product or item being procured or used.
- **"Click to Accept"** means a type of Contract with non-negotiable terms and conditions that is accepted by the click of an approval button instead of another form signature.
- **"Contract"** means any document (including Adobe templates or contracts provided by a third-party) that requires a signature, or any other manifestation of assent to signify that the parties intend to be legally bound to the terms of the document, including Click To Accept.
- **"Purchase Order"** is the order request to the Vendor for the goods/services that will be provided to Adobe once all internal approvers have been obtained.
- **"Purchase Requisition"** is the initial request by the Business Owner to get internal approval for the purchase of goods/services from a Vendor. These requisitions are reviewed by Cost Center Manager, FP&A, and Procurement.
- **"Risk Assessors"** includes Legal & Government Relations, Privacy, Compliance, IT Data Security, HR, Finance etc. who are responsible for reviewing the respective risk assessment topic in graphiteConnect.
- **"Vendor"** means the third party that is receiving funds for goods and/or services that will be provided to Adobe.

13. Related Documents

The following documents are related to this policy:

- VRMO Charter and framework
- Third Party Risk Management (TPRM) Process (Mapped)
- GEN-SOP-01-007 Conflict of Interest Master Policy
- GEN-SOP-01-009 Business Gifts and Hospitality Policy
- GEN-SOP-01-001 Code of Business Conduct
- GEN-SOP-01-006 Global Anti-Corruption Policy and Procedures
- PTP-SOP-01-001 Vendor Master Creation and Change
- PTP-SOP-09-001 Business Travel and Expense Reimbursement Policy
- PTP-SOP-07-005 Equipment Leasing Policy
- PTP-SOP-07-002 Fixed Assets Policy
- PTP-SOP-02-005 Procuring, Accounting, Audit, Tax and Related Services from Independent Audit Firms
- ISY-SOP-02-008 Data Classification and Handling Policy
- PTP-SOP-01-002 Third Party Payment Vendor Policy
- LGL-SPO-01-014 Acceptable Form of Signature
- LGL-SOP-01-017 Contract Signature Policy
- LGL-SOP-01-009 Revenue-Related Contract Policy
- LGL-SOP-01-016 Commercial Contracts Policy
- HTR-SOP-01-006 Global Contingent Worker Policy
- Adobe Provider Data Processing Agreement: Information Security and Privacy Terms
- Consulting and Services General Terms and Conditions
- Business Continuity Policy
- Disaster Recovery Standard
- Business Impact Analysis Standard

14. Document History

VERSION	ISSUE DATE	CHANGES	APPROVAL
1.0	07/15/2022	Initial version, reviewed and approved in accordance with IAU-SOP-01-001.	Reviewed and approved in accordance with #IAU-SOP-01-001.
2.0	07/31/2024	Minor revisions throughout, with updates to VRMO Strategy in Section 1.2 and Business Owner NSJ responsibilities in Section 3.	Reviewed and approved in accordance with #IAU-SOP-01-001.